ID: SECURITY-POL00002-STN00074
Drivers: Gary Gomez, Gaurav Pahuja
Classification: Internal
Version: 7.0

FedRAMP Environment Protection Standard

Contents

1. Overview
2. Scope
3. Statement
   3.1. NIST Family, Domains, and Mappings
   3.2. Continuous Monitoring (ConMon)
   3.3. Access Control
   3.4. Awareness and Training
   3.5. Audit and Accountability
   3.6. Security Assessment and Authorization
   3.7. Configuration Management
   3.8. Contingency Planning
   3.9. Identification and Authentication
   3.10. Incident Response
   3.11. Maintenance
   3.12. Media Protection
   3.13. Physical and Environment Protection
   3.14. Planning
   3.15. Personnel Security
   3.16. Risk Management
   3.17. Systems and Services Acquisition
   3.18. Systems and Communications Protection
   3.19. Systems and Information Integrity
   3.20. Supply Chain Risk Management
   3.21. Roles & Responsibilities
4. Definitions
5. Governing Policy
6. References
7. Document Properties
8. Document History

1. Overview

This governing document provides requirements that are specific to environments in place for FedRAMP customers, hereafter referred to as FedRAMP environments.

2. Scope

Except as otherwise noted, this Standard applies to all Adobe personnel with logical privileged access to FedRAMP environments.

FedRAMP environments are comprised of the following in-scope Adobe products:

1. Adobe Analytics
2. Adobe Campaign
3. Adobe Creative Cloud for Enterprise
4. Adobe Document Cloud
5. Adobe Learning Manager
6. Adobe Connect Managed Services - GovCloud
7. Adobe Experience Manager Managed Services – GovCloud
8. Adobe Acrobat Sign for Government

FedRAMP environments must adhere to all general Technology Policies and Standards and the requirements outlined in this Standard.

3. Statement

3.1. NIST Family, Domains, and Mappings

3.1.1 Adobe FedRAMP environments have adopted the security controls and structure from the National Institute of Standards and Technology (NIST) found in Special Publication (SP) 800-53, Rev 5, *Security and Privacy Controls for Federal Information Systems*. For ease of use, this document must be organized into NIST security control families—mimicking the NIST SP 80053 and FedRAMP controls structure (**See TABLE 1 below**).

3.1.2 Adobe FedRAMP environments must also adopt Adobe's corporate security policies and standards. Below is a mapping of the NIST Family/Domain and Adobe Policy and Standard mapping (**See TABLE 2 below**). Where there is partial coverage, the requirements needed to provide full coverage are called out in this Standard and are only applicable to Adobe FedRAMP environments.

3.1.3 Adobe FedRAMP environments must also adopt a continuous monitoring program (**see section 3.2**) based on the Department of Homeland Security (DHS) Continuous Diagnostics and Mitigation (CDM) Program. The continuous

monitoring program leverages capabilities and tools that identify cybersecurity risks on an ongoing basis, prioritize these risks based upon potential impacts, and enable cybersecurity personnel to mitigate the most significant problems first.

TABLE 1 – NIST and CDM Mapping

	CDM Capability														
NIST Family/Domain	Hardware Asset Management	Software Asset Management	Configuration Management	Vulnerability Management	Manage Network Access Controls	Manage Trust in People Granted Access	Manage Security Related Behavior	Manage Credentials and Authentication	Manage Account Access	Prepare for Contingencies and Incidents	Respond to Contingencies and Incidents	Design and Build in Requirements Policy and Planning	Design and Build in Quality	Manage Audit Information	Manage Operation Security
AC - Access Control					X	X		X	X						
AT - Awareness and Training							X								X
AU - Audit and Accountability			X											X	
CA - Security Assessment and Authorization				X								X			
CM - Configuration Management	X	X	X												
CP - Contingency Planning										X					
IA - Identification and Authentication					X	X		X							
IR - Incident Response											X				
MA – Maintenance															X
MP - Media Protection						X									X
PE - Physical and Environmental Protection						X									X
PL – Planning										X		X	X		X
PS - Personnel Security						X	X	X							
RA - Risk Assessment				X								X			X
SA - System and Services Acquisition	X	X										X			
SC - System and Communications Protection			X	X	X			X	X				X		
SI - System and Information Integrity			X		X		X			X	X			X	
SR- Supply Chain Risk Management	X	X								X					

TABLE 2 – NIST and Adobe Policy and Standard Mapping

Identifier	NIST Family	Relevant Adobe Policy or Standard	Coverage in Corp Docs
AC	Access Control	Logical Access Policy • Customer Authentication Standard • Logical Access Account Standard • Authentication Standard • Remote Access Standard Information Security Policy • Information Security Management Standard • Network Security Standard Information Systems Operations Policy • Wireless Network Management Standard • Mobile Device Usage Standard	Partial
AT	Awareness and Training	Information Security Policy • Security Awareness Training Standard • Information Security Management Standard • Secure Product Lifecycle Standard	Full
AU	Audit and Accountability	Information Security Policy • Information Security Management Standard • Logging Standard • Security Monitoring Standard Information Systems Operations Policy • Network Time Protocol Standard	Full
CA	Certification, Accreditation, and Security Assessments	FedRAMP Specific and covered below.	None
CM	Configuration Management	Information Security Policy • AWS Security Standard OR Azure Security Standard Information Systems Operations Policy • Change Management Standard Information Systems Asset Management Policy • Software Management Standard Physical Security Policy	Partial
CP	Contingency Planning	Business Continuity Policy • Business Impact Analysis Standard • Disaster Recovery Standard • Data Backup and Restore Standard Information Security Policy • Vendor Information Security Standard	Full
IA	Identification and Authentication	Logical Access Policy • Authentication Standard • Logical Access Account Standard	Full
IR	Incident Response	Information Security Policy • Computer Security Incident Response Standard • Security Monitoring Standard	Full
MA	Maintenance	Information Security Policy	Full

TABLE 2 – NIST and Adobe Policy and Standard Mapping

Identifier	NIST Family	Relevant Adobe Policy or Standard	Coverage in Corp Docs
		• Vendor Information Security Standard Physical Security Policy	
MP	Media Protection	Information Security Policy • Vendor Information Security Standard Information Systems Asset Management Policy • eWaste Disposal Standard	Full
PE	Physical and Environmental Protection	Information Security Policy • Vendor Information Security Standard Physical Security Policy	Full
PL	Planning	Information Systems Operations Policy • Change Management Standard Information Security Policy • Vulnerability Management Standard	Partial
PS	Personnel Security	Logical Access Policy • Logical Access Account Standard Information Systems Asset Management Policy • Employee-Assigned Asset Standard Adobe Code of Business Conduct • Compliance Investigations Standard Contingent Worker Policy Background Check Policy Information Security Policy	Partial
RA	Risk Assessment	Information Security Policy • Risk Management Standard • Vulnerability Management Standard	Partial
SA	System and Services Acquisition	Information Security Policy • Vendor Information Security Standard • Information Security Management Standard • Product Lifecycle Standard • Vulnerability Management Standard • Secure Product Lifecycle Standard • Logging Standard • Computer Security Incident Response Standard • Patch Management Standard Information Systems Operations Policy • Change Management Standard	Partial

TABLE 2 – NIST and Adobe Policy and Standard Mapping

Identifier	NIST Family	Relevant Adobe Policy or Standard	Coverage in Corp Docs
SC	System and Communications Protection	Business Continuity Policy • Availability Monitoring Standard • Disaster Recovery Standard • Data Backup and Restore Standard Information Security Policy • Network Security Standard • Systems Security Logging Standard • Cryptography Standard • Patch Management Standard • Vulnerability Management Standard Information Systems Operations Policy • Network Appliance Standard Logical Access Policy • Authentication Standard • Key Management Standard • Customer Authentication Standard Electronic Communications Policy	Partial
SI	System and Information Integrity	Information Security Policy • Patch Management Standard • Vulnerability Management Standard • Logging Standard • Security Monitoring Standard Information Systems Operations Policy • macOS Desktop Configuration Standard • Windows Desktop Configuration Standard Logical Access Policy • Logical Access Account Standard	Partial
SR	Supply Chain Risk Management	Information Security Policy • Vendor Risk Management Policy Information Security Standard • Vendor Information Security Standard • Critical Vendor Standard Adobe Business Partner Code of Conduct Open-Source Program Office Adobe Provider Data Processing Agreements: Information Security and Privacy Terms Supplier Onboarding	Partial

NOTE: Adobe Information Systems & Security Policies and Standards are classified as Adobe Confidential. These governing documents are available for review after signing a non-disclosure agreement and available for viewing on-site or through a screen share.

NOTE: Privacy control families introduced within Appendix J of NIST SP 800-53 (Rev 5) are not included in the above table as they are determined to be privacy data handling (and Privacy Act notification/management) responsibilities of the individual Federal client agency and are to be addressed within the specific engagement of the FedRAMP environment cloud service instance with prospective clients. FedRAMP environment will endeavor to support individual solutions within contractual engagements, through the implementation of runbook processes, SLAs, or other applicable processes. For additional Adobe-specific data handling requirements see the Adobe Data Classification and Handling Standard and the Adobe Personal Information Protection Policy.

3.1.4 *Procedures*: Relevant procedures (not Policies or Standards) or other process documentation (for example, runbooks) for each family are to be documented by the applicable team hosting the FedRAMP customer environment.

3.1.5 The required FedRAMP Baseline Security Controls and required FedRAMP augmentations are specified in requirements and baseline templates found on https://FedRAMP.gov. Default control assignments of "organization-defined' control parameters are parameters configured and defined in Adobe FedRAMP environments. Some control selections and parameters are defined by the authorizing agency for each supported federal system, which requirements supersede Adobe defined control parameters. The resulting completed control statements will be documented in the applicable System Security Plan (SSP).

3.1.6 The following documents are required to be maintained by Adobe FedRAMP environments:

- Configuration Management Plan
- Contingency Plan Test
- Contingency Plan Test Results
- Contingency Plan
- Incident Response Plan
- Rules of Behavior
- System Security Plan (SSP)
- Control Implementation Summary (CIS)
- eAuthentication Plan/Digital Identity Workbook
- Privacy Threshold Analysis and Privacy Impact Assessment (PTA and PIA) document
- FIPS 199
- Plan of Action and Milestone (POA&M)
- FedRAMP Laws and Regulations
- FedRAMP Security Controls
- User Guides
- Integrated Inventory Workbook
- Supply Chain Risk Management Plan
- Cryptographic Module Table

The below content are requirements unique to FedRAMP and where there is no like Adobe corporate documentation in place. The below requirements are only applicable to Adobe FedRAMP environments.

3.2. Continuous Monitoring (ConMon)

FedRAMP compliance requires a continuous monitoring program be in place and functioning. FedRAMP also requires any changes to the system and environment be approved through the sponsoring government agency through a roadmap that is presented to the sponsoring agency during a monthly continuous monitoring meeting sometimes referred to as ConMon.

As part of the continuous monitoring program, each month Adobe is required to report to their sponsoring agency on the status of vulnerabilities and risks as well as the status of any roadmap items being worked on for upgrades. Depending on the sponsoring agency of the FedRAMP package, these meetings are required to be in person on site or through an online web conference.

Continuous monitoring tasks are required on a regular cadence (Weekly, Monthly, Quarterly, or Annually). A table of required tasks is below:

ConMon Task	Activity	FedRAMP Control ID
Weekly/Monthly Tasks		
Weekly AV alert reviews	Review and action on any AV alerts and critical issues.	CA-7(b), SI-3
Weekly logging alert review	Review and action of System Information Event Monitoring (SIEM) alerts and critical issues.	AU-6; CA-7(b), RA-5(3)
Weekly System alerts review	Review and action of any security monitoring and endpoint protection alerts and critical issues.	CA-7(b), RA-5
Monthly Vulnerability Assessment Scans	Review status of any outstanding vulnerability assessment scan results. Follow up with groups on delayed items for status/resolution and ETA updates. Scan all systems in the FedRAMP system boundary. Update POA&M document with newly identified risks. Issue tickets to correct and track vulnerabilities found. Based on CVSS v3 scoring, High risks (7.0-10) fixed within 30 days, Moderate risks (4.0-6.9) fixed within 90 days, and Low risks (0.1-3.9) fixed within 180 days. Cybersecurity & Infrastructure Security Agency (CISA) Known Exploitable Vulnerability (KEV) Catalog issues must be remediated within the specified timeframe.	CA-7(b), RA-5, SI-2
Monthly RoadMap Items	Review status of current Roadmap milestones.	CA-7(b)
New Customers	Review any new customers being added to FedRAMP environment and report it during the ConMon presentation.	CA-7
Monthly Baseline Configuration Management	Review baseline configuration reports, DISA STIGs and/or CIS system checks. Action any discrepancies through the POA&M and tickets.	CA-7(b), CA-6
Monthly Operating System (OS)/Network Scans	Perform authenticated OS/Network scans on all instances at the OS-level. Action and track all Low, Moderate, and High vulnerabilities through the POA&M and tickets to completion.	CA-7, CM-6, CM-7, RA-5
Monthly Web Application Scans	Perform web application scans on any public facing web applications or interfaces (Including VPN interfaces, public facing web interfaces).	CA-7, CM-6, CM-7, RA-5

ConMon Task	Activity	FedRAMP Control ID
	Action and track all Low, Moderate, and High vulnerabilities through the POA&M and tickets to completion.	
Monthly Database Scans	On a monthly basis all database applications are scanned, and issues are reviewed, ranked, and resolved. Action and track all Low, Moderate, and High vulnerabilities through the POA&M and tickets to completion.	CA-5, CM-6, CM-7, RA-5
Monthly Container Scans	Perform vulnerability scans on production container images per FedRAMP Container Vulnerability Scanning Guidance. Action and track all Low, Moderate, and High vulnerabilities through the POA&M and tickets to completion.	CM-6, CM-7, RA-5
Monthly update Plan of Action and Milestones (POA&M)	Review and update the plan of action and milestones monthly.	CA-5
Monthly review of functions, ports, protocols, and services	Review of all allowed functions, ports, protocols, and services. When review is complete, the list of unnecessary functions, ports, protocols, and services are submitted as proposed configuration changes to the system.	CA-7(b)
Monthly update as needed to Inventory	Updated as needed and submitted to the AO	CM-08
Quarterly Tasks		
Quarterly Logging Capacity Review	Review logging capacity on a quarterly basis to ensure adequate space is available for logs.	CA-7(b)
Quarterly Review of Software Whitelist	Review the list of software allowed to execute in the environment.	CM-7(5)
Annual Tasks		
Annual Contingency Plan test presented to Government sponsor for Review	Create and submit the FedRAMP contingency plan test to the government agency for approval prior to testing.	CA-7(b)
Annual review of the contingency plan	Review and update, as necessary, the contingency plan, including personnel, for the information system.	CP-1
Annual training of personnel with contingency responsibilities.	Conduct training for individuals with contingency responsibilities.	CP-2, CP-3, AT-3
Annual test of the contingency plan	Conduct a test of the contingency plan.	CP-4
Annual third-party penetration test	Penetration testing for operating systems, applications/web applications, databases, infrastructure.	CA-8 (1), SI-8(2)

ConMon Task	Activity	FedRAMP Control ID
	Penetration testing includes a phishing campaign of privileged users. Red Team exercises to simulate attempts adversaries to compromise systems. Penetration testing may include mobile applications if in scope for the FedRAMP authorized system.	
Annual review of auditable events	Review and update, as necessary, the types of audit events sent from FedRAMP servers and infrastructure to SIEM.	AU-2
Annual incident response plan test presented to Government sponsor for Review	Create and submit the FedRAMP incident response plan test to the government agency for approval prior to testing.	CA-7(b)
Annual review of the incident response plan	Review and update, as necessary, the incident response plan, including personnel, for the information system.	IR-1, IR-8
Annual training of personnel with incident response responsibilities.	Conduct training for individuals with incident response responsibilities.	IR-2, IR-9
Annual test of the incident response plan	Conduct a test of the incident response plan.	IR-3
Annual data backup testing	Conduct a test and restore of system backups. Modify plan for any lessons learned.	CP-9, IA-5(13)
Annual review of backup information	Review backup information to ensure backups are whole and data can be restored.	CA-7
Annual review of capacity planning	Review the capacity of FedRAMP information systems to ensure sufficient capacity for current and planned growth in the environment.	CA-7
Annual code scan	Conduct an annual code scan for customer (non-off the shelf) application code implemented in the FedRAMP environment.	CA-2 (2), CA-7, SA-11, SI-2(a)
Annual review of policy and procedures	Conduct an annual review of policies and procedures supporting the FedRAMP environment.	AC-1(b), AU1, CA-1, CA-2, CM-1, IA-1, MA-1, MP-1, PE-1, PL-1, PL-8, PS-1, RA-1, RA3, SA-1, SC-1(b), SI-1(b)
Annual review and update of the System Security Plan	Review and update, as necessary, the FedRAMP System Security Plan.	PL-2
Annual access agreement signed	Individuals requiring access to FedRAMP systems are required to sign access agreements (or Rules of Behavior) annually.	PS-6
Annual security awareness training	Security awareness training for all information system users (January). Security awareness training also includes training on how to handle/care for log in credentials.	AT-1 IA-1 AT-2 (2); AT-3 AR-5

ConMon Task	Activity	FedRAMP Control ID
	Security awareness training for recognizing and reporting potential indicators of insider threat, common attack vectors. Annual Privacy Training.	
Annual role-based security awareness training	Annual role-based security training for individuals with system roles in the FedRAMP environment.	AT-3
Annual review of exceptions of traffic flow policy	Review exceptions that have been identified/approved for traffic flows during the last year to approve continuation of the exception or removal of the exception.	CA-7, SC-7(c)
Annual review of system users, groups, roles, and application accounts	Review system users, application users, groups, and roles.	AC-2, CA-7, AC-6(7)
Annual Review of Position Risk designation	Review positions/roles and ensure the current risk designation is appropriate to the role.	PS-2
Annual Periodic Task review of position categorization	Review the security categorization of the positions assigned to the FedRAMP environment.	PS-2
Annual review of third-party service agreements	Review service agreements of third parties on an annual basis.	AC-20(a)
Annual review of baseline configuration for information systems	System baselines are reviewed annually.	CM-2
Annual risk assessment	Perform annual risk assessment including the likelihood and magnitude of harm, from the unauthorized access, use, disclosure, disruption, modification, or destruction of the information system and the information it processes, stores, or transmits.	RA-3
Annual review from third party auditor	Third party assessor audits environment (or a subset of controls) annually.	CA-2(b), CA-7(3), RA-5, SA-11, SC-23 (3)
Annual Access Privilege review	Review and evaluate privileges/roles that are assigned employees with access to production environments to ensure they are accurate.	AC-2, AC-6, CM-5(b), AC-6(7)

3.3. Access Control

3.3.1 In addition, encryption as access enforcement extends to furnished desktop computers or laptops that store sensitive information. While encryption is the preferred technical solution for protection of sensitive information on all desktop or laptop computers, adequate physical security controls and other management controls are acceptable mitigations for the protection of desktop computers with the approval of the Security Manager or his/her designated representative.

3.3.2 Publicly accessible content - Only designated individuals that have been authorized and trained to ensure that publicly accessible content does not contain non-public information must post such content. Publicly accessible content must be reviewed for non-public information prior to posting onto the organizational information system and at least quarterly. Any non-public information discovered within the publicly accessible organizational information system must be removed.

3.4. Awareness and Training

Adherence to mapped Corporate Information Systems and Security Policies & Standards provides coverage. See TABLE 2 above.

3.5. Audit and Accountability

Adherence to mapped Corporate Information Systems and Security Policies & Standards provides coverage. See TABLE 2 above.

3.6. Security Assessment and Authorization

Certification, Accreditation, and Security Assessments

3.6.1 All General Support Systems (GSSs) (i.e., virtual machines and related cloud infrastructure) and Major Applications (MAs) (i.e., application code) must be certified by the Business Owner and accredited by the FedRAMP environment Security Manager or his/her designated representative to ensure that the security controls for each GSS or MA mitigate risk to an acceptable level for protecting the confidentiality, integrity, and availability (CIA) of the FedRAMP environment information and information systems. All certification and accreditation (C&A) and security assessment activities must be conducted in accordance with applicable FedRAMP environment procedures.

3.6.2 Unless there are major changes to a system, re-certification, and re-accreditation of GSSs, MAs, and application systems must be performed every three (3) years. If there are major changes to the GSS, MA, or application system, re-certification and re-accreditation must be performed whenever the changes occur. Also, re-accreditation and/or re-certification must be performed upon the completion of the certification/accreditation action lists, in the case of an interim accreditation. Further, the requirements for re-accreditation/re-certification are listed in section 4.4.6, Security Accreditation (CA-6).

3.6.3 If the FedRAMP environment Security Manager or his/her designated representative is not satisfied that the system is protected at an acceptable level of risk, an interim accreditation can be granted to allow time for implementation of additional controls. Interim approval must be granted only by the FedRAMP environment Security Manager or his/her designated representative in lieu of a full denial to process. Interim approval to operate is not a waiver of the requirement for management approval to process. The information system must meet all requirements and receive management approval to process by the interim approval expiration date. No extensions of interim accreditation must be granted except by the FedRAMP environment Security Manager or his/her designated representative.

3.6.4 As part of the system Certification and Accreditation (C&A), an independent evaluation based on the system security level may be performed and the results analyzed. Considering the evaluation results from the system testing, IS Risk Assessment (RA), System Security Plan (SSP), independent system tests and evaluations, the Business Owner and System Developer/Maintainer must certify that the system meets the security requirements to the extent necessary to protect FedRAMP environments information adequately and meets an acceptable level of risk. Final accreditation must be made by the FedRAMP environment Security Manager or his/her designated representative.

Security Assessments

3.6.5 Routine assessments of all FedRAMP environment information systems must be conducted prior to initial operational capability and authorization to operate; prior to each re-authorization to operate; or when a significant change to the information system occurs. Routine assessments of all FedRAMP environment information systems must determine if security controls are implemented correctly, are effective in their application, and comply with applicable laws, Executive Orders, directives, policies, regulations, standards, and guidance. Routine assessments must be conducted every 365 days, in accordance with NIST SP 800-53 or an acceptable alternative methodology, to monitor the effectiveness of security controls. Findings are subject to reporting requirements as established by applicable laws, Executive Orders, directives, policies, regulations, standards, and guidance.

Plan of Action & Milestones (POA&M)

3.6.6 A POA&M must be developed, implemented, and updated monthly based on the findings from security control assessments, security impact analyses, and continuous monitoring activities. The POA&M must document the planned, implemented, and evaluated corrective actions to repair deficiencies discovered during the security control assessment, and to reduce or eliminate any known vulnerability in the information system.

3.6.7 Personnel must be designated to assign, track, and update risk mitigation efforts. Designated personnel must define and authorize corrective action plans and monitor corrective action progress.

Security Accreditation

3.6.8 Explicit authorization to operate the information system must be received from the FedRAMP environment agency authorizing official or his/her designated representative prior to the system being placed into operations. If the authorization is an interim approval to operate, then the authorization must be granted based on the designated security category of the information system. An explicit corrective action plan may be developed, implemented effectively, and monitored by the authorizing official. Re-authorization must be obtained prior to continued operation:

- At least every three (3) years;
- When substantial changes are made to the system;
- When changes in requirements result in the need to process data of a higher sensitivity;
- After the occurrence of a serious security violation which raises questions about the validity of an earlier certification; and
- Prior to expiration of a previous accreditation.

3.7. Configuration Management

3.7.1 A CM Plan must be developed by the organization that addresses roles, responsibilities, and configuration management processes and necessary procedures; defines configuration items for the information system and when in the SDLC the configuration items are placed under configuration management; and establishes the means for identifying configuration items throughout the SDLC and a process for managing the configuration of the configuration items.

3.8. Contingency Planning

Adherence to mapped Corporate Technology Policies & Standards provides coverage. See **TABLE 2** above.

3.9. Identification and Authentication

Adherence to mapped Corporate Technology Policies & Standards provides coverage. See **TABLE 2** above.

3.10.Incident Response

Adherence to mapped Corporate Incident Response Plan provides coverage for FedRAMP Li-SaaS authorized systems. See **TABLE 2** above.

Adherence to mapped FedRAMP Moderate Incident Response Plan provides coverage for FedRAMP Moderate authorized systems.

3.11. Maintenance

Adherence to mapped Corporate Technology Policies & Standards provides coverage. See **TABLE 2** above.

3.12.Media Protection

Adherence to mapped Corporate Technology Policies & Standards provides coverage. See **TABLE 2** above.

3.13.Physical and Environment Protection

Adherence to mapped Corporate Technology Policies & Standards provides coverage. See **TABLE 2** above.

3.14.Planning

3.14.1 Rules of Behavior (ROBs) must be established and made readily available, to clearly delineate user responsibilities and expected behavior of all Business Owners, users, operators, and administrators with regard to information and information system usage. Before authorizing access to the information system and/or information and annually thereafter, the organization must receive a signed acknowledgement from all users indicating that they have read, understand, and agree to abide by the ROBs.

3.14.2 No personal use of organization-owned or leased equipment and resources must be permitted.

3.14.3 All FedRAMP environment information systems and major applications must be covered by an SSP, which is consistent with the intent of NIST SP 800-18. The SSP must document the operation and security requirements of the system/application and the controls in place for meeting those requirements. The SSP must be approved by appropriate organization officials and incorporated into the information resources management strategic plan. The information contained in the SSP is subject to reporting requirements as established by applicable laws, Executive Orders, directives, policies, regulations, standards, and guidance, including, but not limited to, applicable FedRAMP environment Procedures.

3.14.4 PIAs must be conducted for FedRAMP environment information systems. The PIAs must be compliant with the Adobe Privacy policy.

3.14.5 A criticality/sensitivity rating (e.g., non-sensitive, national security, public trust) must be assigned to all positions within the organization. The criticality/sensitivity rating must be in compliance with the Federal Office of Personnel Management (OPM) policy and guidance. Screening criteria must be established based on the information system access given to the individuals filling those positions. All positions must be reviewed every three (3) years for criticality/sensitivity rating.

3.15.Personnel Security

3.15.1 A criticality/sensitivity rating (e.g., non-sensitive, national security, public trust) must be assigned to all positions within the organization. The criticality/sensitivity rating must be in compliance with OPM policy and guidance. Screening criteria must be established based on the information system access given to the individuals filling those positions. All positions must be reviewed every year for criticality/sensitivity rating.

3.15.2 Prior to being granted access, all employees and contractors who require access to FedRAMP environment information or information systems must be screened and reinvestigated periodically, consistent with the criticality/sensitivity rating of the position. For prospective employees, references background checks must be performed before issuance of a User ID. Security agreements must be required for employees and contractors assigned to work with mission critical information.

3.16. Risk Management

3.16.1 FedRAMP environment information systems and major applications must be documented in an SSP, which is consistent with NIST SP 800-18 and using the approved FedRAMP templates. The SSP must be approved by appropriate organization officials (identified within the SSP) and incorporated into the information resources management strategic plan. The information contained in the SSP is the basis for system accreditation, and subject to reporting requirements as established by applicable laws, Executive Orders, directives, policies, regulations, standards, and guidance, in accordance with applicable FedRAMP environment Procedures

3.16.2 FedRAMP environment information systems and the information processed, stored, or transmitted by the systems must be categorized in accordance with applicable laws, Executive Orders, directives, policies, regulations, standards, and guidance, including, but not limited to the, FedRAMP environment System Security Level by Information Type. The security categorization (including supporting rationale) must be explicitly documented. Designated senior-level officials within FedRAMP environment must review and approve the security categorizations. FedRAMP environment must conduct security categorizations as an organization-wide activity with the involvement of the FedRAMP environment Director, Security Manager, and Business Owners.

3.16.3 All FedRAMP environment information systems categorized as high or moderate must be considered sensitive or to contain sensitive information. All FedRAMP environment information systems categorized as low must be considered non-sensitive or to contain non-sensitive information. All FedRAMP environment information systems must implement minimum security requirements and controls as established in the current FedRAMP environment IS Standards, based on security categorization of the system.

3.17. Systems and Services Acquisition

3.17.1 For acquisition of security and security-enabled commercial-off-the-shelf (COTS) information technology products, when multiple products meet FedRAMP environment requirements, preference must be given to products that have been evaluated and validated against a validated U.S. Government Protection Profile for a specific technology type if such a profile exists or, if a profile does not exist, the product must rely on cryptographic functionality to enforce its security policy.

3.17.2 For acquisition of security and security-enabled commercial-off-the-shelf (COTS) information technology products, verify that vendors comply with Federal Acquisition Regulation (FAR) Subpart 7.103, and Section 889 of the John S. McCain National Defense Authorization Act (NDAA) for Fiscal Year 2019 (Pub. L. 115-232), and FAR Subpart 4.21, which implements Section 889 (as well as any added updates related to FISMA to address security concerns in the system acquisitions process).

3.17.3 In alignment with the Vendor Information Security Standard, where service providers (for example, AWS) fulfill certain security requirements a responsibility matrix must be established and maintained.

3.17.4 A written acknowledgement must be maintained outlining Adobe's and the vendor's responsibility to protect data in the FedRAMP environment.

3.17.5 Service providers operating in the Adobe FedRAMP environment must be prohibited from outsourcing system functions overseas, unless explicitly authorized, in writing, by the Adobe FedRAMP environment management.

3.17.6 An interconnection agreement between service providers and Adobe is maintained. Interconnected security or service tools must follow laws.

3.18. Systems and Communications Protection

3.18.1 FedRAMP environments must leverage FIPS validated cryptographic modules for data encryption, data storage, data processing, and multi-factor authentication in accordance with FIPS 140-2, FIPS 140-3, and NIST 800-63.

3.18.2 FedRAMP environments must establish usage restrictions and implementation guidance for Voice over Internet Protocol (VoIP) technologies based on the potential to harm FedRAMP environment information systems. The organization must document, monitor, and implement controls for the use of VoIP within an FedRAMP environment information system. When VoIP is implemented, the organization must adhere to the NIST SP 800-58 guidance.

3.18.3 Running non-authorized collaborative computing mechanisms on FedRAMP environment information systems must not be allowed.

3.19. Systems and Information Integrity

Adherence to mapped Corporate Technology Policies & Standards provides coverage. See **TABLE 2** above.

3.20. Supply Chain Risk Management

A plan for managing supply chain risks associated with the research and development, design, manufacturing, acquisition, delivery, integration, operations and maintenance, and disposal of the following systems, system components or system services.

3.21. Roles & Responsibilities

Roles and responsibilities are outlined within each FedRAMP environment's System Security Plan (SSP) that is maintained separately.

4. Definitions

Term	Definitions
3PAO	Third party assessment organization
AO	Authorizing Official

Term	Definitions
ATO	Authorization of Operate
C&A	Certification & Accreditation
Change Control Model	The processes and procedures for implementing changes to the environment.
CISA	Cybersecurity and Infrastructure Security Agency
Configuration Management Plan	Plan/Document detailing the baseline configuration requirements and details for all system types within a system boundary
Contingency Plan	A document detailing what to do in the event of an outage including required recovery time objectives and priority of system restoration in a FedRAMP environment.
Contingency Plan Test	A test of the effectiveness of the contingency plan
Contingency Plan Test Results	The documented results and summary of the contingency plan test
Continuous Diagnostics and Mitigation (CDM) Program	Continuous monitoring program
Continuous Monitoring Meeting (ConMon)	Monthly reporting of system risks by Adobe to federal agency customers on the health and security posture of the FedRAMP environment.
Control Implementation Summary (CIS)	A document defining who is responsible for implementing each required FedRAMP control.
eAuthentication document	Document defining the electronic authentication requirements to minimize the potential impact of authentication errors and misuse of credentials
FedRAMP	Federal Risk and Authorization Program
FedRAMP System	The set of servers, firewalls, computers, applications, and functions that FedRAMP customers consume or that support the administration and security of the FedRAMP environment.
FIPS 199	Federal Information Processing Standards
FISMA	Federal Information Security Management Act of 2014
General Support Systems (GSSs)	A system that supports customer major applications or provides administrative and security support to the environment.
GSA	General Services Administration
IaaS	Infrastructure as a Service
Incident Response Plan	A documented plan of how to handle security incidents in the environment
KEV	Known Exploitable Vulnerability
Major Applications (MAs)	The primary application used by Adobe customers in the FedRAMP environment
NIST Family/Domain	National Institute of Standards and Technology 800-53 documented categories of security controls
OPM	The U.S Office of Personnel Management serving as the chief human resources agency and personnel policy manager for the Federal Government,
PaaS	Platform as a Service

Term	Definitions
Plan of Action and Milestone (POA&M)	A document of all risks identified in a FedRAMP system and the plan for each documented risk/vulnerability on remediation and resolution efforts.
Privacy Threshold Analysis and Privacy Impact Assessment (PTA and PIA) document	Annual documented review to determine if PII, as defined by OMB M-07-16, is collected by any FedRAMP information system component. If PII is collected an assessment of system and security impact is conducted of the defined information types is conducted.
Readiness Assessment Report (RAR)	Report generated by the 3PAO describing to the AO the readiness of a system for a FedRAMP authorization
Rules of Behavior (ROBs)	Adobe defined rules that are understood and followed to help ensure the security, integrity, availability, and usage of systems.
SaaS	Software as a Service
Supply Chain Risk Monitoring Plan (SCRMP)	A plan for managing supply chain risks.
System Security Plan (SSP)	Document describing all pertinent NIST 800-53 controls and how they are implemented within the FedRAMP system.

5. Governing Policy

Adherence to the governing Policy referenced below is required to be compliant with this Standard:

- Information Security Policy

6. References

- Continuous Dialogistic and Monitoring Program
- System Life Cycle Approach for Security and Privacy
- Guidelines on Security and Privacy in Public Cloud Computing
- FedRAMP SA-4 Control Update
- FedRAMP Container Vulnerability Scanning Guidance

7. Document Properties

Coordinator	Ensures Review, Approval and Publication; Facilitates Discussions	Harrison Martorana, Technology Compliance Product Owner
Driver	Subject Matter Expert; Owner of Content; Works with Contributors	Gary Gomez, FedRAMP Compliance Product Owner Gaurav Pahuja, FedRAMP Compliance Product Owner
Approver	Approves Document	Rahat Sethi, Director, Tech GRC Bryan Hildebrandt, Manager FedRAMP, TechGRC
Contributor	Provides Recommendations; Subject Matter Expert; Critical Reviewer	Click here for Contributor list

Informed	Notified of Publications	Click here for Informed list

8. Document History

Version	Approval Date	Changes	Approved By
6.0	November 2023	No Major Changes Minor Changes • Section 3.2 –Updated penetration testing attack vectors. • Section 3.6.8 –Updated security authorization section to assign authorization responsibility to agency authorizing official. • Section 3.10 –Included Adobe Commercial Incident Response Plan as in scope for FedRAMP LI-SaaS offerings.	Mitch Nelson, Sr Director Worldwide Managed Services Damon Cooper, Sr Director, Adobe Sign Infrastructure and Quality Rahat Sethi, Director, Tech GRC
7.0	February 2025	Major Changes • Sections related to Exceptions and Violations were removed since it is duplicative content within the governing policy Minor Changes • Section 2 – Scope verbiage updated • Table 1 - Removed PM Project Management control family • Table 1 - Added SR Supply Chain Risk Management control family • Table 2 - added SR Supply Chain Risk Management control • Section 3 - Updated NIST 800-53 from rev 4 to rev 5 • Section 3.1.6 - Added FedRAMP Security Controls, User Guides, Integrated Inventory Workbook, Supply Chain Risk Management Plan and Cryptographic Module Table • Section 4 - Added SCRMP • Section 3.2 - Added Quarterly Review of Software Whitelist activity	Rahat Sethi, Director, Tech GRC Bryan Hildebrandt, Manager FedRAMP, TechGRC